PoisonedCredentials Lab

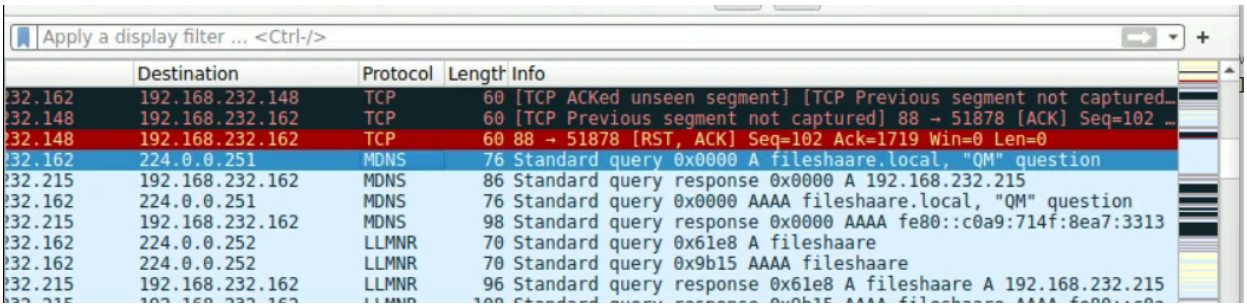
1. Kịch bản

- Tổ chức phát hiện tăng hoạt động mạng đáng ngờ nghi ngờ là tấn công poisoning như Link-Local Multicast Name Resolution và NetBIOS Name Service. Các attack này khai thác giao thức để chặn traffic và làm lộ user credential

2. Write up

1. In the context of the incident described in the scenario, the attacker initiated their actions by taking advantage of benign network traffic from legitimate machines. Can you identify the specific mistyped query made by the machine with the IP address 192.168.232.162?

- Yêu cầu: attacker bắt đầu hành vi bằng cách lợi dung traffic từ máy hợp lệ → điều tra máy hợp lệ có hành vi bất thường
- As: fileshaare
- Từ kịch bản, tìm kiếm các truy vấn liên quan LLMNR phát hiện truy vấn viết sai chính tả
    - Bắt đầu bằng NBNS: phân giải tên NetBIOS thành địa chỉ IP
    - LLMNR: khi DNS lỗi, LLMNR/NBT-NS gửi đến mạng cục bộ hỏi thông tin tên máy chủ (tin vào bất kì ai phản hồi đầu tiên)
    - Hoạt động trên UDP cổng 5355



	Destination	Protocol	Length	Info
232.162	192.168.232.148	TCP	60	[TCP ACKed unseen segment] [TCP Previous segment not captured…
232.148	192.168.232.162	TCP	60	[TCP Previous segment not captured] 88 → 51878 [ACK] Seq=102 …
232.148	192.168.232.162	TCP	60	88 → 51878 [RST, ACK] Seq=102 Ack=1719 Win=0 Len=0
232.162	224.0.0.251	MDNS	76	Standard query 0x0000 A fileshaare.local, "QM" question
232.215	192.168.232.162	MDNS	86	Standard query response 0x0000 A 192.168.232.215
232.162	224.0.0.251	MDNS	76	Standard query 0x0000 AAAA fileshaare.local, "QM" question
232.215	192.168.232.162	MDNS	98	Standard query response 0x0000 AAAA fe80::c0a9:714f:8ea7:3313
232.162	224.0.0.252	LLMNR	70	Standard query 0x61e8 A fileshaare
232.162	224.0.0.252	LLMNR	70	Standard query 0x9b15 AAAA fileshaare
232.215	192.168.232.162	LLMNR	96	Standard query response 0x61e8 A fileshaare A 192.168.232.215

2. We are investigating a network security incident. To conduct a thorough investigation, We need to determine the IP address of the rogue machine. What is the IP address of the machine acting as the rogue entity?

- Yêu cầu: Điều tra sự cố an ninh mạng cần xác định IP của máy gây sự cố
- As: 192.168.232.215
- Trong LLMNR/NBT-NS Poisoning
  - User truy cập domain không thể phân giải → Win gửi LLMNR/NBT-NS hỏi máy nào trong LAN có domain kia thì gửi IP
  - Hacker theo dõi và phản hồi
  - User kết nối và gửi thông tin xác thực

232.162	224.0.0.251	MDNS	76	Standard query 0x0000 A fileshaare.local, "QM" question
232.215	192.168.232.162	MDNS	86	Standard query response 0x0000 A 192.168.232.215
232.162	224.0.0.251	MDNS	76	Standard query 0x0000 AAAA fileshaare.local, "QM" question
232.215	192.168.232.162	MDNS	98	Standard query response 0x0000 AAAA fe80::c0a9:714f:8ea7:3313
232.162	224.0.0.252	LLMNR	70	Standard query 0x61e8 A fileshaare
232.162	224.0.0.252	LLMNR	70	Standard query 0x9b15 AAAA fileshaare
232.215	192.168.232.162	LLMNR	96	Standard query response 0x61e8 A fileshaare A 192.168.232.215
232.215	192.168.232.162	LLMNR	108	Standard query response 0x9b15 AAAA fileshaare AAAA fe80::c0a…
232.162	224.0.0.251	MDNS	76	Standard query 0x0000 A fileshaare.local, "QM" question
232.162	224.0.0.251	MDNS	76	Standard query 0x0000 AAAA fileshaare.local, "QM" question
232.215	192.168.232.162	MDNS	86	Standard query response 0x0000 A 192.168.232.215

3. As part of our investigation, identifying all affected machines is essential. What is the IP address of the second machine that received poisoned responses from the rogue machine?

- Yêu cầu: tìm ra các máy bị ảnh hưởng (nhận phản hồi của máy attacker)
- As: 192.168.232.176
- Dựa vào thông tin các cuộc hội thoại → máy attacker giao tiếp với 2 máy

Ethernet · 11 | IPv4 · 11 | IPv6 | TCP · 14 | UDP · 42

Address A	Address B	Packets	Bytes	Packets A → B	Bytes A → B
192.168.232.148	192.168.232.176	55	12 kB	26	5 kB
192.168.232.162	192.168.232.148	108	24 kB	60	15 kB
192.168.232.162	192.168.235.255	1	92 bytes	1	92 bytes
192.168.232.162	224.0.0.251	8	608 bytes	8	608 bytes
192.168.232.162	224.0.0.252	8	560 bytes	8	560 bytes
192.168.232.176	192.168.235.255	5	460 bytes	5	460 bytes
192.168.232.176	224.0.0.251	8	584 bytes	8	584 bytes
192.168.232.176	224.0.0.252	8	536 bytes	8	536 bytes
192.168.232.176	239.255.255.250	7	5 kB	7	5 kB
192.168.232.215	192.168.232.162	17	2 kB	17	2 kB
192.168.232.215	192.168.232.176	44	6 kB	31	4 kB

4. We suspect that user accounts may have been compromised. To assess this, we must determine the username associated with the compromised account. What is the username of the account that the attacker compromised?

- Yêu cầu: tìm kiếm username để xác định xem tài khoản có bị lộ chưa
- As: janesmith

238	398.450927	192.168.232.215	192.168.232.176	SMB2	266 Negotiate Protocol Request
239	398.451663	192.168.232.176	192.168.232.215	SMB2	388 Negotiate Protocol Response
240	398.465476	192.168.232.215	192.168.232.176	SMB2	240 Session Setup Request, NTLMSSP_NEGOTIATE
241	398.466660	192.168.232.176	192.168.232.215	SMB2	453 Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CHALLENGE
242	398.476497	192.168.232.215	192.168.232.176	SMB2	598 Session Setup Request, NTLMSSP_AUTH, User: cybercactus.local\janesmith
243	398.521789	192.168.232.176	192.168.232.215	TCP	60 445 → 34643 [ACK] Seq=986 Ack=1016 Win=2101248 Len=0
250	398.591702	192.168.232.176	192.168.232.215	SMB2	139 Session Setup Response
251	398.603950	192.168.232.215	192.168.232.176	SMB2	230 Encrypted SMB3

5. As part of our investigation, we aim to understand the extent of the attacker's activities. What is the hostname of the machine that the attacker accessed via SMB?

- Yêu cầu: hiểu phạm vi attacker, tìm hostname của thiết bị mà attacker có thể truy cập qua SMB
- As: ACCOUNTINGPC
- Tìm kiếm liên quan giao thức SMB/SMB2 với thông tin: Session Setup Response
- STATUS_MORE_PROCESSING_REQUIRED: cho biết quả trình xác thực NTLM đang diễn ra

239	398.451663	192.168.232.176	192.168.232.215	SMB2	388 Negotiate Protocol Response
240	398.465476	192.168.232.215	192.168.232.176	SMB2	240 Session Setup Request, NTLMSSP_NEGOTIATE
241	398.466660	192.168.232.176	192.168.232.215	SMB2	453 Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CHALLENGE
242	398.476497	192.168.232.215	192.168.232.176	SMB2	598 Session Setup Request, NTLMSSP_AUTH, User: cybercactus.local\janesmith
243	398.521789	192.168.232.176	192.168.232.215	TCP	60 445 → 34643 [ACK] Seq=986 Ack=1016 Win=2101248 Len=0
250	398.591702	192.168.232.176	192.168.232.215	SMB2	139 Session Setup Response
251	398.603950	192.168.232.215	192.168.232.176	SMB2	230 Encrypted SMB3
252	398.605390	192.168.232.176	192.168.232.215	SMB2	190 Encrypted SMB3
257	398.618720	192.168.232.215	192.168.232.176	SMB2	178 Encrypted SMB3
258	398.619076	192.168.232.176	192.168.232.215	SMB2	178 Encrypted SMB3

- Quy trình xác thực xảy ra thế nào?
  - SSO (Signle Sign-On): win nghĩ bạn dùng tài khoản đang login để đăng nhập kết nối SMB
  - Silent Authen: Win tự lấy NTLM hash trong bộ nhớ mang đi để xác thực mà không làm phiền user
- Sau khi lấy được NTLM hash → chuyện gì xảy ra?
  - Có thể Pass-The-Hash để đăng nhập

- SMB Relay: chuyển tiếp truy vấn phản hồi từ user hợp lệ đến máy thứ 3 để giả mạo và lấy quyền truy cập

3. Mitre ATTCK

1. **Credential Access**

- T1557.001: **Adversary-in-the-Middle: LLMNR/NBT-NS Poisoning and SMB Relay**
  - Giả mạp host để liên lạc nhằm thu thập hoặc chuyển tiếp thông tin xác thực

2. **Collection**

- T1557.001: tương tự ở trên
- T1039: **Data from Network Shared Drive**
  - Xác thực SMB và tìm kiếm dữ liệu từ thư mục chia sẻ mạng